

← ↻ ☆ Systemic Fraud: Interactions API Bypasses Paid Retention Policies & UI Deletion (CWE-459)

+1

Hotlists

Mark as Duplicate





Comments (3) Dependencies (0) Duplicates (0) Blocking (0) Resources (7)

WAI

Customer Issue

P4

+ Add Hotlist

 STATUS UPDATE No update yet.

 DESCRIPTION

bu...@google.com created issue on behalf of György Istókolics #1

Sep 22, 2026 03:26PM



Summary: Systemic Fraud: Interactions API Bypasses Paid Retention Policies & UI Deletion (CWE-459)

Program: Google VRP

URL: https://aistudio.google.com/

Vulnerability type: Sensitive data exposure

Details

Description: !!! MANDATORY NOTICE TO HUMAN REVIEWER !!! Do not close this report with an automated triage bot. Closing this as "Intended Behavior" constitutes a formal corporate admission of consumer fraud, GDPR Article 17 violations, and financial deception against paying Enterprise customers. The Vulnerability (The 3-Layered Fraud Architecture): Forensic testing of the Google AI Studio, Google Drive Trash, and the Gemini API log settings proves that Google's architecture is structurally incapable of executing a genuine data purge, resulting in a three-layered systemic fraud:

1. The UI Deception (Pointer Unlinking): The AI Studio UI guarantees that deleted chats "cannot be recovered." In reality, the system performs no backend database purge. It merely moves a client-side .json pointer file to the Google Drive Trash, leaving the raw prompt payload active on the Interactions API backend.
2. The Backend Zombie Persistence: Emptying the Drive Trash removes the pointer, blinding the UI. However, if a user utilizes the official Google Drive Recovery tool to restore the discarded .json pointer days or weeks later, the AI session instantly resurrects in milliseconds. This is empirical proof that the backend "hot storage" never received a cascade-delete signal.
3. The Financial Scam (Bypassing Paid Retention TTL): In the AI Studio Gemini API log settings, paying customers can configure strict data retention timeframes (e.g., 7 days instead of the 55-day default). However, because the Interactions API backend operates in a disconnected silo from the Drive UI, it ignores these rules. If a user pays for a 7-day retention policy, deletes a chat, empties the trash, and then restores the .json pointer on Day 20 using the Drive Recovery Robot, the chat fully resumes. This proves the backend never executed the paid 7-day purge. Google is actively charging Enterprise customers for data governance and deletion features that the system mathematically fails to execute. Steps to Reproduce: Configure an active AI Studio project with a strict retention policy (e.g., 7 days) in the log settings. Create a chat session with sensitive prompts. Click "Delete permanently" in the UI (Observe the fraudulent warning). Empty the Google Drive Trash. Wait well beyond the configured TTL (e.g., wait 20 days). Use the Google Drive Recovery tool to restore the .json pointer. The chat resumes instantly with full memory, proving the paid retention policy was ignored and the backend data was never destroyed.

Attack scenario

Impact: This is a critical CWE-459 (Incomplete Cleanup) vulnerability. Google is systematically deceiving users (GDPR Art. 12 & 17) and actively defrauding enterprise customers by charging them for retention policies (TTL) that the backend fails to honor. I demand a substantive review by

Reporter  istokovicsgyorgy79@gmail.com 

Type  Customer Issue

Priority P4

Severity S4

Status Won't fix (Intended behavior)

Access Default access View

Expanded Access?

Assignee

Verifier

Collaborators  

CC  istokovicsgyorgy79@gmail.com
wo...@google.com
Un-CC me

Code Changes --

Pending Code Changes --

Disclosure information --

Reporter e-mail --

Requested charity --

Found In --

Targeted To --

Report Analysis

Note: The feedback below was generated as part of an automated analysis of the submitted report. It is *NOT* part of the report that was submitted by the user.

Out of Scope

The report is out of scope for the selected VRP. Please review our program rules.

 **Képernyőkép 2026-09-06 191250.png**

262 KB [View](#) [Download](#) 

COMMENTS

All comments

↓ Oldest first

sp...@google.com <sp...@google.com> [#2](#)

Sep 22, 2026 03:26PM

NOTE: This is an automatically generated email

Hi! Many thanks for sharing your report.

This email confirms we've received your message. We'll investigate the issue you've reported and get back to you once we have an update. In the meantime, you might want to take a look at the  [list of frequently asked questions about Google Bug Hunters](#).

Also, if you have not already done so, create a profile on  [the Google Bughunters site](#) if you'd like us to publicly recognize your contribution:

-  [Leaderboard](#) – You'll be added here if we issue a reward for your report.
-  [Honorable Mentions](#) – You'll be added here if you are not in the Hall of Fame, but we file a security vulnerability bug based on your report.

Note that we only act on reports concerning vulnerabilities or technical security problems in one of our products. This is not the correct channel if you need to resolve a problem with your account, or want to report non-security bugs or suggest a new product feature.

Cheers,
Google Security Bot

 [Follow us](#) on Twitter!

sp...@google.com <sp...@google.com> [#3](#)

Sep 22, 2026 03:27PM

Status: Won't Fix (Intended Behavior).

NOTE: This is an automatically generated email

Our Vulnerability Reward Programs (VRPs) are built on key pillars of respect, constructive collaboration, and good faith to ensure a professional environment. These principles are formalized in our [🔒Code of Conduct](#) which all participants are expected to uphold.

A review has determined that activity associated with your account is inconsistent with these principles and constitutes a **violation of the Code of Conduct**.

Therefore, in line with our stated enforcement policy, **your account has been permanently excluded from our VRPs, and we will no longer review or act on any new submissions from your account, including this one**. Please be aware that we will not see any replies to this or other future reports. This action is final and not open to appeal.

For a detailed explanation of our community standards and prohibited behaviors, please refer to the full [🔒Code of Conduct](#) document.

Sincerely,
Google Security Bot